SAIZERO

GROUND ZERO DEFENCE

PHISHING EMAIL DETECTION & AWARENESS REPORT

Prepared By	Satheesh Nithiananthan — CyberLycan
Organisation	SAIZERO — Ground Zero Defence
Client	Pinnacle Capital Group LLC
Prepared For	Michael D. Carter — CISO
Report Date	March 2026
Report Version	1.0
Classification	CONFIDENTIAL

⚠ CONFIDENTIAL — DO NOT DISTRIBUTE ⚠

TABLE OF CONTENTS

1. Executive Summary
2. About SAIZERO — Ground Zero Defence
3. Client Profile
4. What Is Phishing?
5. Analysis Methodology
6. Tools Used
7. Email Sample Analysis
   7.1 Sample 1 — Brazilian Tax Refund Scam
   7.2 Sample 2 — Microsoft Account Impersonation (Domain Spoofing)
   7.3 Sample 3 — XRP Ripple Crypto Scam (Mailgun Abuse)
8. Phishing Indicators Summary
9. Risk Classification Summary
10. Prevention Guidelines
11. Employee Do's and Don'ts
12. Conclusion

2. ABOUT SAIZERO — GROUND ZERO DEFENCE

Organisation	SAIZERO — Ground Zero Defence
Analyst	Satheesh Nithiananthan (CyberLycan)
Specialisation	Vulnerability Assessment, Penetration Testing, Phishing Analysis, SOC & Threat Detection
GitHub	github.com/Satz-N-Sentry
TryHackMe	tryhackme.com/p/SatzNithii
Tagline	*Every shadow has a hunter*

SAIZERO — Ground Zero Defence is a cybersecurity practice focused on offensive security, vulnerability assessment, and security awareness. Operating under the CyberLycan identity, SAIZERO provides professional security analysis, penetration testing reports, and employee awareness programmes designed to protect organisations from real-world cyber threats.

This phishing awareness report was produced as part of SAIZERO's security consulting services, designed to help organisations understand the phishing threat landscape and equip their employees with the knowledge to identify and report malicious emails.

> **CyberLycan — Every shadow has a hunter**

3. CLIENT PROFILE

Organisation	Pinnacle Capital Group LLC
Industry	Financial Services & Investment
Location	New York, NY, USA
Website	www.pinnaclecapitalgroup.com
Organisation Size	320 employees
Contact	Michael D. Carter — CISO
Assessment Scope	Phishing email analysis and employee awareness programme
Assessment Date	March 2026
Reason for Assessment	Surge in phishing emails targeting finance team — 3 employees clicked malicious links in the past 30 days

Pinnacle Capital Group LLC engaged SAIZERO — Ground Zero Defence following reports of suspicious emails targeting their finance team. Three employees had clicked malicious links in the 30 days prior to this engagement, prompting an urgent phishing awareness review. This report aims to educate staff on how to identify phishing attempts and provide the IT team with technical recommendations to reduce phishing exposure.

1. EXECUTIVE SUMMARY

This report presents the findings of a phishing email analysis conducted on behalf of Pinnacle Capital Group LLC. The analysis examined three real-world phishing email samples, identifying common attack patterns, social engineering techniques, and malicious indicators used by threat actors to compromise user credentials and business systems.

All three email samples were classified as confirmed phishing attempts. The samples demonstrate a range of attack vectors including credential harvesting, invoice fraud, executive impersonation, and prize scams — covering the most common phishing categories encountered in corporate environments.

Immediate awareness training and technical controls are recommended to reduce the organisation's exposure to phishing-based threats.

PHISHING	SUSPICIOUS	SAFE	TOTAL
3	3	0	3

4. WHAT IS PHISHING?

Phishing is a type of social engineering attack where cybercriminals send fraudulent emails that appear to come from legitimate sources — such as banks, IT departments, government agencies, or company executives — in order to trick recipients into revealing sensitive information, clicking malicious links, or downloading malware.

Common Phishing Attack Types

Attack Type	Description	Target
Credential Harvesting	Fake login pages steal usernames and passwords	All users
Spear Phishing	Targeted attack using personal details about the victim	Specific individuals
Whaling / BEC	Impersonating CEO or executives to authorise payments	Finance teams
Invoice Fraud	Fake invoices redirecting payments to attacker accounts	Accounts payable
Prize / Reward Scam	Fake prize notifications to harvest personal data	General public
IT Helpdesk Scam	Fake IT support emails harvesting credentials	Employees

5. ANALYSIS METHODOLOGY

Each phishing email sample was analysed using the following structured approach:

- Step 1 — Header Analysis: Examine email headers to identify sender IP, mail server path, SPF/DKIM/DMARC authentication results, and spoofed addresses
- Step 2 — Sender Domain Analysis: Check sender domain against known phishing databases and WHOIS records
- Step 3 — Link Inspection: Safely examine URLs using browser tools and online scanners without clicking them
- Step 4 — Content Analysis: Identify social engineering techniques — urgency, fear, authority, reward
- Step 5 — Indicator Identification: Document all phishing red flags found in the email
- Step 6 — Risk Classification: Classify the email as Safe / Suspicious / Phishing
- Step 7 — Documentation: Record findings in a structured format for the awareness report

6. TOOLS USED

Tool	Purpose
Google Admin Toolbox	Email header analysis — trace routing and auth
MXToolbox	Header analysis + SPF/DKIM/DMARC checks
VirusTotal	URL and domain reputation scanning
URLScan.io	Safe URL inspection without clicking
WHOIS Lookup	Domain registration and age verification
PhishTank	Known phishing URL database
Thunderbird	Open .eml files — view email body and extract raw headers
Git	Version control — track and push evidence to repository
Github	Public repository hosting for submission deliverables

7. EMAIL SAMPLE ANALYSIS

EMAIL SAMPLE #1 Liberacao de IRPF - 6NwlyfzWcsNerv0	
Sender	`prestonconstance587@gmail.com (Free Gmail — Brazilian tax refund scam)`
Date	26 July 2023 — 17:59:01 UTC
Risk Classification	**PHISHING**
Email Headers	`From: [BB] - Seu saldo foi liberado <prestonconstance587@gmail.com> Return-Path: prestonconstance587@gmail.com Received: from a3.domain via smtp.gmail.com Sender IP: 209.85.160.178 (Google mail server) SPF: PASS (Gmail — legitimate service abuse) DKIM: PASS (Gmail signature verified) DMARC: PASS (policy=none — not enforced) Hop 3: IS ON A BLACKLIST Delivered in: 6 seconds (automated bulk sender)`
Email Body (Excerpt)	*Clientephishing@pot, Saldo para credito em conta. (Translation: Balance ready for credit in your account) Mais informacoes em anexo. (Translation: More information in the attachment) Protocolo: 4793122145117905827 (Fake government reference number) [MALICIOUS ATTACHMENT PRESENT — multipart/mixed]*
Phishing Indicators	1. Free Gmail used — tax authority NEVER sends from Gmail 2. Campaign tracking code in subject: 6NwlyfzWcsNerv0 3. Fake government protocol number: 4793122145117905827 4. Malicious attachment present — multipart/mixed content 5. Generic greeting — Clientephishing@pot (not personalised) 6. SPF/DKIM PASS via Gmail — legitimate service abuse 7. Hop 3 server IS ON A BLACKLIST 8. Delivered in 6 seconds — automated bulk campaign 9. DMARC policy=none — domain not enforced 10. Origin from a3.domain — attacker device identity hidden
Potential Impact	Malware execution via attachment — banking credentials stolen, CPF (Brazilian national ID) harvested, financial account access compromised. Attack bypasses all spam filters because Gmail SPF/DKIM passes. Targets thousands of Brazilian citizens during annual IRPF tax refund season. Automated bulk delivery confirmed by 6 second send time.
Analyst Verdict	**CONFIRMED PHISHING — Social Engineering: Malware Delivery via Attachment (OWASP SE-01). Delete immediately. Never open unexpected attachments. Verify tax refund status directly on official government portal only. Tax authorities never send attachments via free Gmail accounts.**

EMAIL SAMPLE #2	**Microsoft account unusual signin activity**
Sender	`Microsoft account team <no-reply@access-accsecurity.com> — Sending domain: thcultarfdes.co.uk`
Date	26 July 2023 — 21:13:36 UTC
Risk Classification	**PHISHING**
Email Headers	`From: Microsoft account team <no-reply@access-accsecurity.com> Sending domain: thcultarfdes.co.uk Return-Path: bounce@thcultarfdes.co.uk Reply-To: solutionteamrecognizd02@gmail.com (attacker Gmail) Sender IP: 89.144.44.2 (Warsaw, Poland — MSCode.pl data centre) SPF: NONE — no SPF record on thcultarfdes.co.uk DKIM: NONE — email not digitally signed DMARC: PERMERROR — no DMARC record found SCL: 5 BCL: 6 X-Priority: 1 (fake HIGH importance) Hop 4: IS ON A BLACKLIST Tracking pixel: thebandalisty.com (6/98 VirusTotal detections, -78 community score) SPF: FAIL DKIM: FAIL DMARC: FAIL`
Email Body (Excerpt)	*Microsoft account team, We detected something unusual about a recent sign-in. Country/region: Russia / Moscow IP address: 103.225.77.255 Date: Wed, 26 Jul 2023 21:13:35 Platform: Windows 10 | Browser: Firefox [Report The User] button → mailto:solutionteamrecognizd02@gmail.com ALL links go to attacker Gmail — not Microsoft Hidden tracking pixel (loads silently on open): http://thebandalisty.com/track/o39376LnAvM...*
Phishing Indicators	1. SPF/DKIM/DMARC all FAILED — completely unauthenticated email 2. Sending domain thcultarfdes.co.uk — no SPF/DKIM/DMARC records 3. From domain access-accsecurity.com — never registered ($13.48 available) 4. Sending IP 89.144.44.2 from Warsaw Poland — Microsoft is US-based 5. ALL links route to attacker Gmail — not Microsoft 6. Reply-To: solutionteamrecognizd02@gmail.com — victim emails attacker 7. Hidden tracking pixel — thebandalisty.com (6/98 VirusTotal detections) 8. 731 URLScan records — confirmed large-scale mass campaign 9. Fake Russia/Moscow login — designed to create panic 10. X-Priority:1 — artificially marked HIGH importance 11. BCL:6 SCL:5 — Microsoft flagged suspicious, still delivered 12. VirusTotal community score: -78 on tracking domain
Potential Impact	Victim contacts attacker directly believing they report to Microsoft. Attacker obtains confirmed active email and open communication channel. Tracking pixel gives attacker real-time data: open time, IP address, email client. 731 URLScan records confirm hundreds to thousands of victims targeted simultaneously.
Analyst Verdict	**CONFIRMED PHISHING — Brand Impersonation: Credential Harvesting + Victim Tracking (OWASP A07:2021). Real Microsoft alerts come from @microsoft.com domains only. Never click links in security alert emails. Go directly to account.microsoft.com in a new browser tab to verify any alerts.**

EMAIL SAMPLE #3	**More benefits from Ripple with the Allocation Program**
Sender	`CoinDesk <coindesk@mg.areafellowship.com> — Sent via Mailgun`
Date	27 July 2023 — 15:06:03 UTC
Risk Classification	**PHISHING**
Email Headers	`From: CoinDesk <coindesk@mg.areafellowship.com> Sending domain: mg.areafellowship.com (compromised church subdomain) Sender IP: 198.61.254.55 (Mailgun Technologies — Chicago, USA) Phishing domain: mail123-ripple.net (Russian server) SPF: PASS (Mailgun — legitimate service abuse) DKIM: PASS (mg.areafellowship.com signed via Mailgun) DMARC: bestguesspass (no real DMARC record) SCL: 9 — MAXIMUM spam score (still delivered) Hop 5: IS ON A BLACKLIST Hop 0: Origin = unknown (attacker hidden) AbuseIPDB: 22 abuse reports on sending IP URLScan: Russian flag confirmed on mail123-ripple.net SPF: FAIL DKIM: FAIL DMARC: FAIL`
Email Body (Excerpt)	*Welcome to The Node! This is Daniel Kuhn... (Real CoinDesk journalist — used without permission) After the favorable ruling of the July 13 Court Decision, the Ripple Foundation is thrilled to introduce the Token Allocation Program. 15% increase on initial funding balance. Up to 30% balance boost for early adopters. ALL links in email go to: https://mail123-ripple.net/[victim email in hex] ?c_id=coindesk-27bc8277-ccf1-41fd-bb5b-1281a7728da9 Tracking pixel (loads silently on open): https://mail123-ripple.net/[hex email].gif*
Phishing Indicators	1. CoinDesk impersonation — real domain is coindesk.com 2. Sent via compromised church subdomain mg.areafellowship.com 3. SCL:9 maximum spam score — still delivered via SPF/DKIM 4. Origin server completely hidden (Hop 0 = unknown) 5. ALL links redirect to Russian-hosted mail123-ripple.net 6. Victim email hex-encoded in URL — individual click tracking 7. Hidden tracking pixel reports open time and IP to attacker 8. NICENIC Chinese throwaway registrar — domain for one campaign 9. Server hosted in Russia — chosen for anonymity 10. Real journalist Daniel Kuhn named without permission 11. Real court ruling (July 13 2023) used as social bait 12. Unrealistic promise — 15-30% crypto balance boost 13. 22 abuse reports on Mailgun sending IP 14. mail123-ripple.net dropped — available for $14.886. SPF/DKIM/DMARC all FAIL
Potential Impact	Victim connects cryptocurrency wallet to fake Ripple website and approves transaction — ALL XRP and other tokens transferred to attacker wallet immediately. Blockchain transactions are completely irreversible. No bank to call. No chargeback. No recovery. Total financial loss. Attack cost to attacker: under $30.
Analyst Verdict	**CONFIRMED PHISHING — Financial Fraud: Cryptocurrency Investment Scam (OWASP A05:2021). Never connect cryptocurrency wallet to any site reached via email link. Always navigate directly to ripple.com. No legitimate token program requires wallet connection from an email.**

8. PHISHING INDICATORS SUMMARY

Indicator	Description	Found In
Spoofed Sender Domain	From address mimics legitimate brand but uses different domain	All 3 samples
SPF/DKIM/DMARC Fail	Email authentication checks all failed	Sample - 2 and 3 (1 passes via Gmail)
Urgency Language	Time pressure to force quick action without thinking	All samples
Tracking Pixel	Hidden 1x1 pixel tracks victim open time and IP	Sample - 2 (thebandalisty.com)
Generic Greeting	'Dear User', 'Dear Employee' — not personalised	Samples - 1, 2, 3
Suspicious URLs	Links use fake domains mimicking legitimate sites	Samples - 1, 2, 3
Mismatched Reply-To	Reply-To address differs from sender address	All 3 samples
Legitimate Service Abuse	Real services used to bypass spam filters	Sample - 1 (Gmail) and sample - 3 (Mailgun)
Unrealistic Financial Promise	15-30% crypto boost — investment scam bait	Sample - 3

9. RISK CLASSIFICATION SUMMARY

#	Email Subject	Attack Type	Classification	Recommended Action
1	Liberacao de IRPF - 6NwlyfzWcsNerv0	Social Engineering — Malware Delivery (OWASP SE-01)	**PHISHING**	Delete — Never open attachment + Report
2	Microsoft account unusual signin activity	Brand Impersonation — Credential Harvesting (OWASP A07:2021)	**PHISHING**	Do NOT click — go to account.microsoft.com +Report
3	More benefits from Ripple...	Financial Fraud — Crypto Investment Scam (OWASP A05:2021)	**PHISHING**	Delete — Never connect wallet via email link + Report

10. PREVENTION GUIDELINES

For Organisations

- Enable SPF, DKIM, and DMARC on all company email domains to prevent spoofing
- Deploy an email security gateway (e.g. Proofpoint, Mimecast) to filter phishing emails
- Implement Multi-Factor Authentication (MFA) on all accounts — even if credentials are stolen, MFA prevents login
- Run regular phishing simulation exercises to test employee awareness
- Establish a clear process for employees to report suspicious emails
- Enforce a verbal confirmation policy for all financial transfers requested via email
- Use email banners to flag external emails — '[EXTERNAL]' in subject line

For Employees

- Always verify the sender's full email address — not just the display name
- Hover over links before clicking to see the real destination URL
- Never enter credentials on a page you reached by clicking an email link
- Be suspicious of any email creating urgency or demanding secrecy
- Call the person directly using a known number to verify financial requests
- Report all suspicious emails to your IT or security team immediately
- Never open unexpected attachments — even from known senders

11. EMPLOYEE DO'S AND DON'TS

✓ DO	✗ DON'T
Check the full sender email address	Trust the display name alone
Hover over links before clicking	Click links in unexpected emails
Call to verify unusual requests	Act on urgency without verifying
Report suspicious emails to IT	Delete quietly without reporting
Use MFA on all accounts	Rely on passwords alone
Verify payment requests by phone	Transfer money based on email only
Check URLs match official domains	Enter credentials after clicking email links
Keep software and antivirus updated	Open unexpected attachments

12. CONCLUSION

This analysis identified and confirmed three real-world phishing email samples representing distinct attack categories encountered by organisations daily. All three samples demonstrated multiple phishing indicators including social engineering tactics, email authentication abuse or failure, urgency-based psychological manipulation, and malicious infrastructure designed to evade detection.

The most sophisticated sample was the XRP Crypto Scam (Sample 3) which combined legitimate email service abuse, a compromised church subdomain, a pixel-perfect fake website hosted in Russia, and real news events as social engineering bait. This level of sophistication represents the current state of advanced phishing campaigns targeting both individuals and corporate finance teams.

The most effective defences against phishing are a combination of technical controls (SPF/DKIM/DMARC, MFA, email filtering) and human awareness training. Employees who can identify phishing indicators are the last line of defence and the most valuable security asset an organisation can have.

> **Every phishing email has a hunter. Train your people to be that hunter.**

Satheesh Nithiananthan | SAIZERO — Ground Zero Defence | 2026